

# B13705023 蔡承叡 HW10

---

## A. Miscs

---

### 1.

- SSID (Service Set Identifier) 就是我們打開 wifi 選單看到的 wifi 名字，多個 AP 可以廣播同個 SSID
- BSSID (Basic Service Set Identifier) 即為一個特定 AP 的 MAC 地址
- 舉例來說，NTU\_PEAP 是一個 SSID，範圍極大，在台大校內有很多 AP，每個對於 NTU\_PEAP 的 AP 都有相同的 SSID，但 BSSID 不同 (能區分不同 AP)。

參考資料：

<https://eureka.patsnap.com/blog/what-is-bssid/>

<https://www.fortinet.com/tw/resources/cyberglossary/service-set-identifier-ssid>

### 2.

- 兩者都可以。
  - 第一個情境：csie 系館內的 AP 能夠 host csie-guest, csie-5G 等 SSID
  - 第二個情境：如第一題的舉例一樣，NTU\_PEAP 是個範圍很大的 SSID，需要很多 AP 幫忙廣播訊號

參考資料：

<https://community.cisco.com/t5/wireless-mobility-knowledge-base/multiple-ssid-configuration-on-a-cisco-access-point/ta-p/3132386>

## B. HTML's Wi-Fi Problem

---

### 1.

- $P_r = P_t G_t G_r \left(\frac{\lambda}{4\pi d}\right)^2$  而且固定  $d \cdot P_t \cdot G_t \cdot G_r$  的情況下， $\pi$  又是 constant， $P_r \propto \lambda^2$ 。又  $\lambda = \frac{c}{f}$ ，所以  $P_r \propto \frac{1}{f}^2$

- 所以  $\frac{P_{r2.4G}}{P_{r5G}} = \left(\frac{5}{2.4}\right)^2 \approx 4.34$ ，換算成 dB 得到  $10\log_{10}(4.34) \approx 6.375dB$ 。所以 2.4GHz 應該比 5GHz 接收訊號還強。

## 2.

- 因為  $G_t, G_r = 0$ ，所以線性增益都是 1。 $\lambda = \frac{3 \cdot 10^8}{5 \cdot 10^9} = 0.06m$ 。帶入 Friis transmission equation 得到  
 $\frac{P_r}{P_t} = 1 \cdot 1 \left(\frac{0.06}{4\pi 1}\right)^2 \approx 2.2797 \cdot 10^{-5}$ ，換算成 dB 得到  
 $10\log_{10}(2.2797 \cdot 10^{-5}) \approx -46.42dB$

參考資料：

[https://en.wikipedia.org/wiki/Isotropic\\_radiator](https://en.wikipedia.org/wiki/Isotropic_radiator)

## 3.

- 先計算教授到各個 AP 的距離：
  - R103-front:
    - $\sqrt{25+400} \approx 20.62m$
  - R103-rear:
    - $\sqrt{625+100} \approx 26.93m$
  - R103-front2
    - $\sqrt{25}=5m$

### 設置前

- 根據 Friis formula 知道在固定  $(G_t, G_r, \lambda)$  的情況下， $(P_r \propto \frac{1}{d^2})$ ，所以
  - 來自 R103-front 的 Signal  $(S \propto \frac{1}{d^2} = \frac{1}{20.62^2} = \frac{1}{425.18})$
  - 來自 R103-rear 的 Interference  $(I \propto \frac{1}{d^2} = \frac{1}{26.93^2} = \frac{1}{725.22})$
- 因為可忽略 noise，所以  $(SINR_{\text{before}} = \frac{S}{I} = \frac{725.22}{425.18} = 1.706)$ ，換算成 dB 得到  $(10\log_{10}(1.706) \approx 2.32dB)$

### 設置後

- $(P_r \propto \frac{1}{d^2})$ 
  - 來自 R103-front-2 的 Signal  $(S \propto \frac{1}{d^2} = \frac{1}{5^2} = \frac{1}{25})$
  - 來自 R103-front 和 R103-rear 的 Interference  $(I \propto \frac{1}{d_1^2} + \frac{1}{d_2^2} = \frac{1}{425.18} + \frac{1}{725.22} \approx 0.00373)$
- $(\text{SINR}_{\text{after}} = \frac{S}{I} = \frac{0.04}{0.00373} = 10.72)$ ，換算成 dB 得到  $(10\log_{10}(10.72) \approx 10.30\text{dB})$
- 比較 2.32 dB 和 10.30 dB，改善了 7.98 dB，所以明顯地讓教授的連線品質變好。

參考資料：

<https://propagationtools.com/wireless/sinr-concept-explained/>

## C. Tiaosu's Hotspot

### 1.

hostapd configuration:

```
# /etc/hostapd/hostapd.conf

interface=wlan0
driver=nl80211
bridge=br0

ssid=tiaosu
hw_mode=g
channel=6
country_code=TW

macaddr_acl=0
auth_algs=2
wpa=0
wep_key0=xxxxxxxxx
wep_tx_keyidx=0
```

參考資料：

<https://wireless.docs.kernel.org/en/latest/en/users/documentation/hostapd.html>

## 2.

- Open System Authentication: 認證，但不認證，也就是任何人對 AP 發送請求 (Authentication Request) AP 都會回傳 Success (Authentication response)。  
因為過程簡潔，常常跟更進階的 security 驗證方法一起用 (PSK，802.1X/EAP)。
- Shared Key Authentication:
  - 首先，client 先對 AP 發送認證請求 (Authentication Request)
  - AP 回傳明文 response (Challenge)
  - Client 接著把明文挑戰加密，送回 AP
  - 最後，AP 會解密這個 response，拿來跟 challenge 比較。如果相同，那 AP 會送回最後的 Response (Success)。

參考資料：

[https://blog.csdn.net/lyndon\\_li/article/details/120160297](https://blog.csdn.net/lyndon_li/article/details/120160297)

<https://dot11ap.wordpress.com/open-system-authentication-shared-key-authentication-and-deauthentication/>

## 3.

### (a)

- File -> Open 開 .cap 檔案
- filter 欄位輸入 wlan.fc.type\_subtype == 0x0b
- 去第一個封包，開 IEEE 802.11 Wireless Management 下面的 Fixed parameters 看到 **Authentication Algorithm: Shared Key**

參考資料：

<https://community.cisco.com/t5/无线文档/原创-802-11抓包中无线帧的类型过滤方法/ta-p/4336511>

### (b)

- 利用了 ARP (Address resolution protocol)
- 手法叫做 ARP Request Replay Attack，原理是 WEP 的 IV 可能的組合不大，只有 16,777,216 種組合，所以 IV 可能會重複使用。攻擊者可以捕獲這些 ARP 封包並重

新發送給 AP，強迫 AP 大量回應，就可以有很多新的 IV。接著可以使用 FMS 方法去破解 WEP key。

參考資料：

[https://www.aircrack-ng.org/doku.php?id=arp-request\\_reinjection](https://www.aircrack-ng.org/doku.php?id=arp-request_reinjection)

[https://en.wikipedia.org/wiki/Fluhrer,\\_Mantin\\_and\\_Shamir\\_attack](https://en.wikipedia.org/wiki/Fluhrer,_Mantin_and_Shamir_attack)

### (c)

- 把 WEPCapture.cap 放到桌面
- aircrack-ng WEPCapture.cap
- 馬上找到 KEY FOUND! [ 63:73:6C:3C:33 ]

### (d)

- Edit -> Preferences -> Protocols -> IEEE 802.11
- 打開 Enable Decryption
- Decryption keys 輸入剛剛找到的 key
- 套用可以看到資料都被解密了！
- 接著 filter http 去找 POST 的欄位
- Host IP: 140.112.30.188, Port = 54321
- 打開下面的 HTML Form URL Encoded 可以看到 "username" = "tiao su", "password" = "ilovecsi"
- 再往下看幾個封包，可以看到 HTTP 200 OK 裡面的 Line-based text data 有 flag: NASA\_HW10{W3P\_15\_N07\_50\_54F3}

參考資料：

<https://wiki.wireshark.org/HowToDecrypt802.11>

## 4.

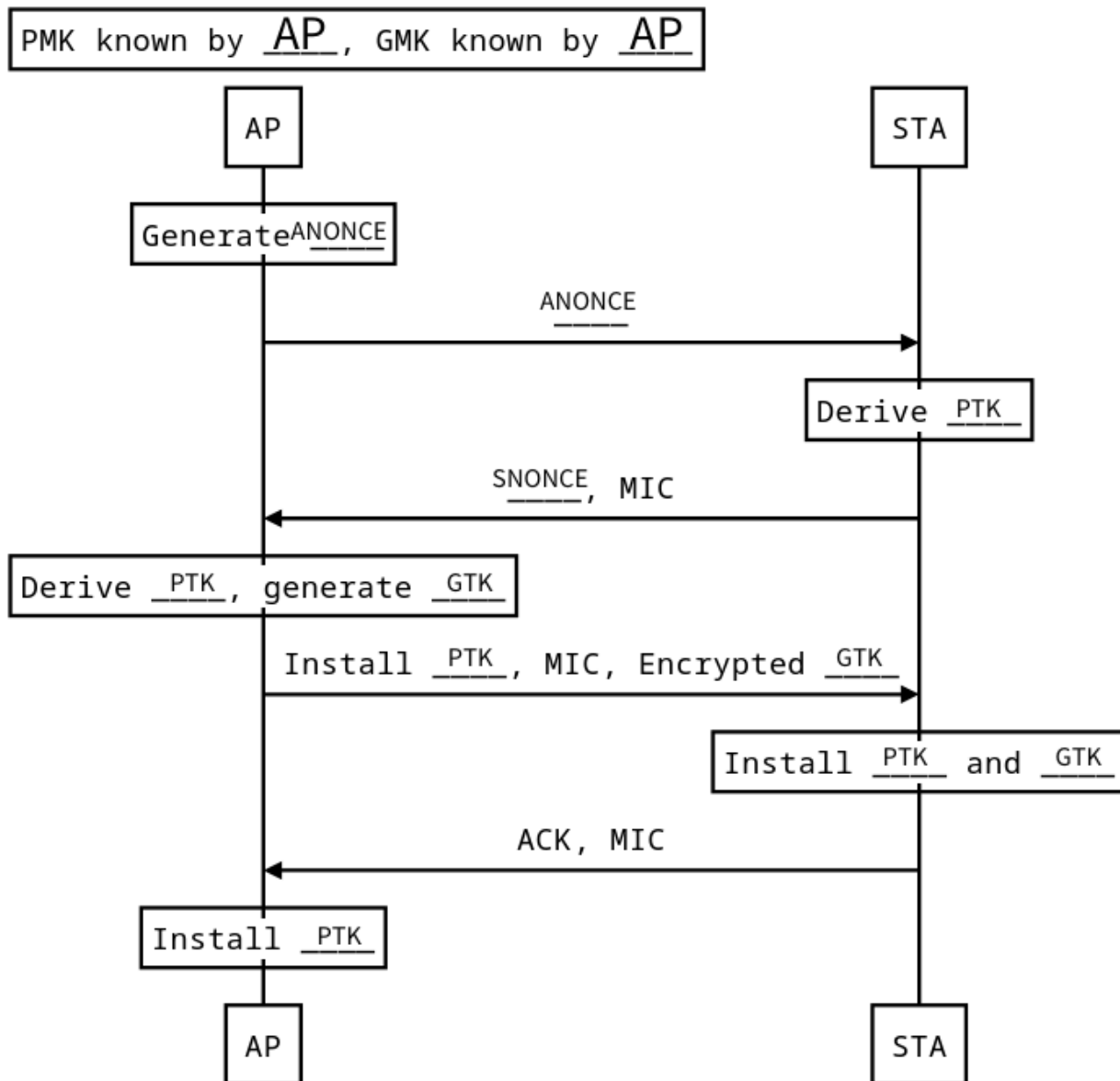
- 大部分同意，但對於 HTTPS 傳輸的帳號密碼不同意。
  - 用 RC4 串流加密和固定的 IV，攻擊者確實可以在幾分鐘之內就破解 WEP 金鑰。(aircrack-ng)
  - 有 KEY 之後就可以看到全部的 Wi-Fi 封包內容。

- 不過 WEP (layer 2) 和 HTTPS (layer 7) 是不同層的加密，就算破解了 WEP，拿到的還是 TLS 加密過後的 HTTPS 資料，在沒有破解 HTTPS 的情況下，根本看不到帳號密碼。

參考資料：

<https://zh.wikipedia.org/zh-tw/有線等效加密>

## 5.



參考資料：

<https://pavelhan.vercel.app/2024-06-07-wifi-wpa2-4way-handshake-details>

<https://zhuanlan.zhihu.com/p/712600869>

## 6.

- 斷線攻擊 (Deauthentication attack) 是濫發或偽造 802.11 無線管理封包 (deauth frame) 以強迫一個 client 和 AP 斷線。
- 要對 passphrase 進行字典攻擊，就要先讓 client 斷線，才能竊聽重新連線時的 WPA/WPA2 4-way 握手。這個握手流程能夠提供字典攻擊的資訊。舉例來說，把字典裡的一個密碼和 SSID 作為 salt 帶入 KDF (key derivation function) 生成一組 hash，然後把這個 hash 跟捕捉到的 nonce (一次性使用碼) 計算 MIC (訊息認證碼)。如果跟捕獲封包中的 MIC 相同，那密碼就是對的。因為是離線運算，所以可以暴力用字典攻擊嘗試破解。

參考資料：

[https://en.wikipedia.org/wiki/Wi-Fi\\_deauthentication\\_attack](https://en.wikipedia.org/wiki/Wi-Fi_deauthentication_attack)

<https://zh.wikipedia.org/zh-tw/Nonce>

## 7.

### (a)

- File -> Open 開 .cap 檔案
- filter 輸入 eapol 看第一個封包，為 AP 傳給 STA
- Client MAC: ba:e0:e8:e8:4f:41, AP MAC: 2c:cf:67:57:78:33

參考資料：

<https://networklessons.com/wireless/eapol-extensible-authentication-protocol-over-lan>

### (b)

- 封包編號 No. 21

| No. | Time     | Source               | Destination          | Protocol | Length | Info                 |
|-----|----------|----------------------|----------------------|----------|--------|----------------------|
| 21  | 2.904543 | RaspberryPi_57:78:33 | ba:e0:e8:e8:4f:41    | EAPOL    | 133    | Key (Message 1 of 4) |
| 23  | 2.926367 | ba:e0:e8:e8:4f:41    | RaspberryPi_57:78:33 | EAPOL    | 157    | Key (Message 2 of 4) |
| 25  | 2.928484 | RaspberryPi_57:78:33 | ba:e0:e8:e8:4f:41    | EAPOL    | 157    | Key (Message 3 of 4) |

### (c)

- 4 次完整 handshake，其中有額外 3 次不是完整的

### (d)

- `aircrack-ng -w rocktiaosu.txt DeAuthCapture.cap` 用這個字典檔破解
- 得到 passphrase 為 [ felwinter ]

### (e)

- Edit -> Preferences -> Protocols -> IEEE 802.11
- Decryption keys 選 wpa-pwd輸入剛剛找到的 passphrase:tiaosu
- 套用，並且在 filter 查 dhcp
- 找到第一個 DHCP ACK 封包，看 Dynamic Host Configuration Protocol (ACK) 之下
- 找到 Your (client) IP address: 192.168.0.1

參考資料：

<https://wiki.wireshark.org/HowToDecrypt802.11>

## 8.

- KRACK 是針對 WPA2，也能盜取用戶訊息。流程是攻擊者會設置一個 evil twin internet, 然後在 client 連線的時候瘋狂重複四向交握的第三部分，每次使用者接受連線請求時，都會解密一小部分資料。攻擊者可以彙總這一系列通訊來破解加密金鑰。

參考資料：

<https://www.cloudflare.com/zh-tw/learning/security/what-is-a-krack-attack/>